

Hallazgos de análisis externo — ERSO 2026-007

- Hallazgos de análisis externo — ERSO 2026-007
 - Resolución y verificación DID como consumidor conforme
 - 1. Resumen
 - 2. Proyectos citados en este informe
 - 3. Hallazgos
 - 4. Aplicación a los criterios de aceptación de la ERSO 007
 - 5. Diferencias de diseño frente a nuestro proyecto
 - 6. Qué aprender y qué hacer con esto
 - 7. Límites de este informe

Hallazgos de análisis externo — ERSO 2026-007

Resolución y verificación DID como consumidor conforme

Proyecto propio	Identidad Digital Soberana SSI (/home/geovani/Descargas/generic/bitacora/new_proyect)
Fecha del análisis	2 de octubre de 2026
Carpetas analizadas	/home/geovani/Workspace/Wallet/Wallet , .../Verifier , .../Issuer , .../Trust , .../librerias
Versión del informe	Actualizado el 2 de octubre de 2026: se añaden los hallazgos de la carpeta librerias y el análisis a fondo del gestor de listas de confianza
Cobertura de esta ERSO	Alta (verificador, validador de confianza y bibliotecas de verificación)
Método	Lectura de código y documentación; no se compiló ni se ejecutó ninguno de los proyectos externos

1. Resumen

La ERSO 007 trata de un **consumidor conforme**: resuelve, valida estructura y relaciones, rechaza lo no conforme y es de solo lectura. El equivalente externo está en el **verificador** (Verifier/eudi-srv-verifier-endpoint), que valida la prueba del titular y emite códigos de rechazo con nombre, y en el **validador de confianza** (Trust/eudi-srv-trust-validator), que decide si una cadena de certificados es confiable **para un contexto concreto**. La diferencia central: ellos resuelven la clave del emisor por certificados x5c; nosotros, por DID. **Complemento (carpeta Librerías)**: las bibliotecas de OpenID4VP y SD-JWT contienen la **lógica de consumo de DID** de la referencia. La regla con que OpenID4VP autentica a un verificador por DID es la misma que aplica nuestro ProofVerifier: la clave debe ser un DID URL **dentro del DID esperado**.

2. Proyectos citados en este informe

Carpeta	Proyecto	Qué es
Verifier	eudi-srv-verifier-endpoint	Backend verificador (Kotlin/Spring)
Trust	eudi-srv-trust-validator	Validador de confianza de cadenas de certificados (Kotlin/Spring)
Verifier	eudi-wallet-rfcs	Especificaciones EWC (RFC 001 a 013)
librerias	eudi-lib-jvm-openid4vp-kt	Biblioteca de OpenID4VP (autenticación del verificador, cifrado de respuesta, DID)
librerias	eudi-lib-jvm-sdjwt-kt	Biblioteca de SD-JWT y SD-JWT VC (verificación, métodos de clave del emisor)
librerias	eudi-lib-android-wallet-core	Biblioteca Android de la cartera EUDI: claves, documentos, confianza, estado, registro de transacciones
librerias	eudi-lib-kmp-stadium	Biblioteca de listas de estado de tokens (draft 12)

3. Hallazgos

La columna *Criterio* indica a qué criterio de aceptación de la ERSO se aplica el hallazgo (el detalle está en la sección 4).

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Rela
1	Verifier/eudi-srv-verifier-endpoint	src/main/kotlin/.../adapter/out/sdjwtvc/SdJwtVcValidator.kt	Exige KB-JWT y valida nonce y audience (validate(..., nonce, audience, ...)).	Equi
2	Verifier/eudi-srv-verifier-endpoint	.../SdJwtVcValidator.kt (enum SdJwtVcValidationErrorCode)	Códigos de rechazo con nombre: ContainsInvalidKeyBindingJwt , IsMissingKeyBindingJwt , UnsupportedHolderPublicKey , StatusNotValid , StatusCheckFailed , UnableToLookupDID ...	Equi INVA KEY_
3	Verifier/eudi-srv-verifier-endpoint	.../SdJwtVcValidator.kt (línea ~136)	IssuerVerificationMethod.usingX5c(...). Existe el código UnableToLookupDID pero no se encontró en el verificador una configuración que resuelva DID.	Conf del e DID.

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Rela
4	Verifier/eudi-srv-verifier-endpoint	.../SdJwtVcValidator.kt (isChainTrustedForAttestation.sdJwtVcIssuance(x5c, vct))	La confianza se decide por tipo de credencial (vct).	Equi "aut (aut
5	Verifier/eudi-srv-verifier-endpoint	application.properties (verifier.validation.statusCheck.enabled=true , kbjwt.clock.skew=PT5S)	Comprueba el estado de revocación y tolera 5 s de diferencia de reloj.	Nues revo
6	Verifier/eudi-srv-verifier-endpoint	.../adapter/out/mso/DeviceResponseValidator.kt	Valida la presentación de mdoc.	Falta
7	Trust/eudi-srv-trust-validator	src/main/kotlin/.../adapter/input/web/TrustApi.kt	Un único endpoint POST /trust con cuerpo TrustQueryTO (chain , verificationContext , useCase).	Equi una :
8	Trust/eudi-srv-trust-validator	.../port/input/trust/IsChainTrustedUseCase.kt (VerificationContextTO)	Contextos: PID, QEAA, EAA, PubEAA, WalletProviderAttestation, WalletRelyingPartyAccessCertificate, WalletRelyingPartyRegistrationCertificate y sus variantes de estado.	Conf cade un co
9	Trust/eudi-srv-trust-validator	.../config/ValidateCertificateChainUsingPKIX.kt; application.properties (enable-certificate-revocation-check=true)	Validación PKIX con revocación (CRL preferida).	Nues el do revo
10	Trust/eudi-srv-trust-validator	.../config/LoTLSources.kt, LoTESources.kt, KeyStoreSources.kt	Fuentes de anclaje: listas de listas ETSI TS 119 612, listas de entidades ETSI TS 119 602 y almacenes Java.	El al nues
11	Trust/eudi-srv-trust-validator	application.properties (dss.file-cache.expiration=PT24H , in-memory-cache.expiration=PT10M) y .../adapter/out/scheduling/	Caché con vencimiento y limpieza programada.	La El prá reso
12	Verifier/eudi-wallet-rfcs	ewc-rfc012-trust-mechanism.md (§4.2.2) y ewc-rfc001/002 (línea ~590 / ~1002)	Pasos para resolver un kid DID: analizar, elegir resolutor, obtener el documento y verificarlo; se prevén x5c y DID.	Resp de n
13	librerías/eudi-lib-jvm-openid4vp-kt	src/main/kotlin/.../openid4vp/internal/request/RequestAuthenticator.kt (lookupKeyByDID , líneas ~309 a 330)	Para client_id de tipo DID: exige solicitud firmada; el kid debe existir y ser un DID URL absoluto; ensure(keyDid == clientId) (si no, "kid should be DID URL sub-resource of ..."); si la búsqueda falla, DIDResolutionFailed.	Equi (DID espe la co crite
14	librerías/eudi-lib-jvm-openid4vp-kt	.../openid4vp/AuthorizationRequestResolver.kt (línea ~466)	RequestValidationError.DIDResolutionFailed(didUrl) entre los errores de validación tipados.	Códi com
15	librerías/eudi-lib-jvm-openid4vp-kt	.../openid4vp/Config.kt (línea ~62, LookupPublicKeyByDIDUrl)	Interfaz inyectable resolveKey(URI) ; el resolutor de DID no forma parte de la biblioteca.	Mism mód desa
16	librerías/eudi-lib-jvm-sdjwt-kt	.../sdjwt/vc/NimbusSdJwtVcVerifierFactory.kt (fromDid)	La búsqueda inyectable devuelve las claves o null ; ante null o excepción, DIDLookupFailure. Contrato de solo lectura.	Equi cons puec
17	librerías/eudi-lib-android-wallet-core	wallet-core/.../trust/EvaluateIssuerTrust.kt y TrustPolicy.kt	Política de confianza configurable por tipo de credencial y contexto: ENFORCE (rechaza, borra el documento y emite DocumentFailed) o INFORM (guarda y adjunta el resultado).	Dos nues rech
18	librerías/eudi-lib-android-wallet-core	wallet-core/.../statium/ (DocumentStatusResolver, TrustEvaluatingJwtSignatureVerifier, VerifyStatusListTokenSignatureX5c)	Consulta de estado de documentos con verificación de la firma del token de estado evaluando confianza.	Cont carp confi verif
19	librerías/eudi-lib-kmp-statium	eudi-lib-kmp-statium/lib/.../statium (GetStatus, VerifyStatusListTokenSignature, StatusListTokenValidations)	Interfaces inyectables para obtener el estado y verificar la firma del token; valores Valid, Invalid, Suspended.	Estru resol reerr

4. Aplicación a los criterios de aceptación de la ERSO 007

Para cada criterio: lo que exige el PDF de la ERSO, dónde está nuestra evidencia y qué hallazgos externos se le aplican.

Criterio 1. Una prueba firmada por la clave resuelta se valida correctamente.

Evidencia que pide la ERSO	Prueba positiva.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-007 §18
Hallazgos aplicables	#1 (Verifier/eudi-srv-verifier-endpoint); #3 (Verifier/eudi-srv-verifier-endpoint); #6 (Verifier/eudi-srv-verifier-endpoint); #12 (Verifier/eudi-wallet-rfcs)
Qué aporta el análisis	El verificador valida la prueba del titular con nonce y audiencia; la clave del emisor se resuelve por certificado, no por DID.

Criterio 2. Una prueba firmada por una clave ajena se rechaza.

Evidencia que pide la ERSO	Prueba negativa.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-007 §19
Hallazgos aplicables	#2 (Verifier/eudi-srv-verifier-endpoint); #4 (Verifier/eudi-srv-verifier-endpoint); #8 (Trust/eudi-srv-trust-validator); #13 (librerías/eudi-lib-jvm-openid4vp-kt)
Qué aporta el análisis	Códigos de rechazo con nombre y confianza decidida por tipo de credencial o contexto, equivalentes a nuestra autorización por relación de verificación. OpenID4VP aplica la misma regla que nuestro DID_MISMATCH: la clave debe ser un DID URL bajo el DID esperado.

Criterio 3. Un documento no conforme, con id desajustado o inexistente, se rechaza.

Evidencia que pide la ERSO	Prueba negativa.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-007 §20
Hallazgos aplicables	#2 (Verifier/eudi-srv-verifier-endpoint); #3 (Verifier/eudi-srv-verifier-endpoint); #5 (Verifier/eudi-srv-verifier-endpoint); #9 (Trust/eudi-srv-trust-validator); #10 (Trust/eudi-srv-trust-validator); #11 (Trust/eudi-srv-trust-validator); #12 (Verifier/eudi-wallet-rfcs); #13 (librerías/eudi-lib-jvm-openid4vp-kt); #14 (librerías/eudi-lib-jvm-openid4vp-kt); #17 (librerías/eudi-lib-android-wallet-core); #18 (librerías/eudi-lib-android-wallet-core); #19 (librerías/eudi-lib-kmp-stadium)
Qué aporta el análisis	El validador de confianza comprueba cadenas con revocación y caché; no se halló una validación de un documento de identidad equivalente a la nuestra.

Criterio 4. El consumidor no realiza operaciones de escritura ni de publicación.

Evidencia que pide la ERSO	Revisión de interfaz y pruebas de solo lectura.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-007 §21
Hallazgos aplicables	#7 (Trust/eudi-srv-trust-validator); #15 (librerías/eudi-lib-jvm-openid4vp-kt); #16 (librerías/eudi-lib-jvm-sdjwt-kt)
Qué aporta el análisis	El validador de confianza expone una sola operación de consulta; el verificador, en cambio, guarda su propio estado. Las dos bibliotecas inyectan la búsqueda de claves como contrato de solo lectura.

5. Diferencias de diseño frente a nuestro proyecto

Tema	Proyectos externos	Nuestro proyecto
Clave del emisor	Certificado x5c y cadena de confianza	DID Document resuelto por HTTPS
Confianza	Por contexto/tipo de credencial	Por relación de verificación del documento
Revocación	CRL y listas de estado	No se revisa
Solo lectura	El verificador guarda su propio estado	Interfaz sin operaciones de escritura
Defensas de red	Cachés, tiempos de espera, límite de tamaño de configuración	Sin redirecciones, tipo de contenido, 128 KiB, 5 s
Caché	Sí, con vencimiento	No

6. Qué aprender y qué hacer con esto

- Para la defensa de la ERSO 007: comparar ProofVerifier con SdJwtVcValidator y mostrar que ambos encadenan comprobaciones y rechazan con código.
- Mejora posible: caché con vencimiento para did-resolver, tomando como modelo Trust/eudi-srv-trust-validator.
- Mejora posible: comprobar el estado de revocación del emisor.
- Decisión pendiente: si se necesita interoperar con verificadores EUDI, hay que ofrecer x5c además del DID.
- Para la defensa del criterio 2: citar lookupKeyByDID de OpenID4VP como la misma defensa implementada por la biblioteca de referencia.
- Idea a evaluar: ofrecer una política ENFORCE / INFORM en el consumidor para distinguir rechazo y aviso.

7. Límites de este informe

- Todo proviene de lectura de código; el comportamiento real no se verificó ejecutando.
- Se citan archivos y, cuando se anotó, números de línea (con ~ si son aproximados); las versiones de los proyectos son las que había en disco el 2 de octubre de 2026.
- "No encontré" significa que las búsquedas realizadas no lo hallaron, no que no exista en ninguna parte del código.
- Los proyectos de referencia EUDI se declaran a sí mismos como versiones de desarrollo no aptas para producción.